FREE GUIDE · AI SYSTEM DESIGN

Every company's AI has 8 layers

A one-page map of how a real company AI assistant is built, plus what to check at each layer. Most teams get the model working and forget layers 5 and 6: who can see what, and where the keys live.

1. API call
2. System prompt
3. RAG (retrieval)
4. Tools (MCP)
5. Identity & access
6. Secrets
7. Guardrails
8. Monitoring & evals

THE BUILDING LAYERS

Layers 1–4: make it work

1 API call

Your app sends the question to a model (GPT, Claude, Gemini, or an open model).

- Set timeouts and retries with backoff
- Pin the model version; upgrades change behaviour
- Stream responses so users see progress

2 System prompt

Tells the model who it is, what it may do, and what it must never do.

- Keep it in version control and review changes
- State refusals explicitly (no salaries, no passwords)
- Never put secrets or internal URLs in it

3 RAG (retrieval)

Before answering, the model reads the relevant pieces of your own documents.

- Chunk documents and store embeddings in a vector database
- Filter results by the user's permissions, not after
- Show sources so answers can be checked

4 Tools (MCP)

The model can call real systems: look up an order, raise a ticket, run a query.

- Give each tool the smallest scope it needs
- Read-only by default; writes need approval
- Validate every argument the model sends

THE SAFETY LAYERS

Layers 5–8: make it safe

5 Identity & access

The AI acts as the user, so it may only see what that user may see.

- Pass the user's identity to every tool and retrieval call
- Enforce role-based access in the backend, not in the prompt
- Test: can an intern's question reach HR data?

6 Secrets

API keys and database passwords the AI system uses to reach other services.

- Keep them in a secrets manager (e.g. Vault, cloud KMS)
- Prefer short-lived, per-task credentials
- Never in code, prompts, logs or the model's context

7 Guardrails

Checks on what goes in and what comes out.

- Input: prompt-injection and jailbreak detection
- Output: PII and secret leak filters
- Hard limits on tokens, cost and tool calls per request

8 Monitoring & evals

Know what the AI did, what it cost, and whether it is still good.

- Log prompts, tool calls and answers (mask personal data)
- Track cost and latency per user and feature
- Run an eval set on every prompt or model change

INTERVIEW PREP

5 questions you'll be asked

How would you stop an AI assistant from leaking data across users?

Pass the user identity into retrieval and tools; enforce access in the backend; filter outputs.

Where should an AI agent's API keys live?

In a secrets manager, issued short-lived and per task, never in code, prompts or logs.

RAG or fine-tuning for company knowledge?

RAG for facts that change and need sources; fine-tuning for tone or format.

How do you know a prompt change didn't break things?

An eval set of real questions with expected answers, run automatically on every change.

How do you control LLM cost in production?

Cache repeated answers, route easy questions to a smaller model, cap tokens per request.

Follow @dabeer.ai

AI system design, cloud and security, explained by an engineer. New reels every week.